

Cuadro A.2(continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
5.30	preparación para las TIC para negocios continuidad	# Correctivo	# Disponibilidad	# Responder	# Continuidad	# Resiliencia
5.35	Independiente repaso de información seguridad	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- teger	# Información_ seguridad_como- seguro	# Gobernanza_ y_Ecosys- tiempo
5.37	documentado operando procedimientos	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #Re- cubrir	# Asset_man- gestion # fisio- cal_seguridad # Sistema_y_ network_secu- ridad #Aplicación ción_seguridad # Secure_con- figuración # Identidad_ y_acceso_ gestión # amenaza_y_ vulnerabilidad_ gestión # Continuidad # Informa- tion_securi- ty_event_man- gestion	# Gobernanza_ y_Ecosys- artículo #Protec- ción #Defensa
6.4	Disciplinario proceso	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #Re- responder	# Human_re- source_secu- ridad	# Gobernanza_ y_Ecosys- tiempo
8.7	Proteccion contra mal- mercancia	# Preventivo # Detective # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #De- tegar	# Sistema_y_ network_secu- ridad #Informa- tion_protec- ción	# Proteccion # Defensa
8.13	Información respaldo	# Correctivo	# Integridad # Disponibilidad	# Recuperar	# Continuidad	# Proteccion
8.16	Supervisión actividades	# Detective # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Detectar #Re- responder	# Informa- tion_securi- ty_event_man- gestion	# Defensa

A.2 Puntos de vista organizacionales

Dado que los atributos se utilizan para crear diferentes vistas de los controles, las organizaciones pueden descartar los ejemplos de atributos propuestos en este documento y crear sus propios atributos con diferentes valores para abordar las necesidades específicas de la organización. Además, los valores asignados a cada atributo pueden diferir entre organizaciones, ya que las organizaciones pueden tener diferentes puntos de vista sobre el uso o la aplicabilidad del control o de los valores asociados al atributo (cuando los valores son específicos del contexto de la organización). El primer paso es comprender por qué es deseable un atributo específico de la organización. Por ejemplo, si una organización ha construido sus planes de tratamiento de riesgos [consulte ISO/IEC 27001:2013, 6.1.3 e)] en función de los eventos, puede desear asociar un atributo de escenario de riesgo a cada control en este documento.

El beneficio de tal atributo es acelerar el proceso de cumplimiento del requisito ISO/IEC 27001 relacionado con el tratamiento de riesgos, que consiste en comparar los controles determinados a través del proceso de tratamiento de riesgos (denominados controles "necesarios"), con aquellos en ISO/IEC 27001:2013, Anexo A (que se emiten en este documento) para garantizar que no se ha pasado por alto ningún control necesario.

Una vez que se conocen el propósito y los beneficios, el siguiente paso es determinar los valores de los atributos. Por ejemplo, la organización podría identificar 9 eventos:

- 1) pérdida o robo del dispositivo móvil;
- 2) pérdida o robo de las instalaciones de la organización;
- 3) fuerza mayor, vandalismo y terrorismo;
- 4) falla de software, hardware, energía, internet y comunicaciones;
- 5) fraude;
- 6) piratería;
- 7) divulgación;
- 8) incumplimiento de la ley;
- 9) ingeniería social.

Por lo tanto, el segundo paso se puede lograr asignando identificadores a cada evento (por ejemplo, E1, E2, ..., E9).

El tercer paso es copiar los identificadores de control y los nombres de control de este documento en una hoja de cálculo o base de datos y asociar los valores de atributo con cada control, recordando que cada control puede tener más de un valor de atributo.

El paso final es ordenar la hoja de cálculo o consultar la base de datos para extraer la información requerida.

Otros ejemplos de atributos organizacionales (y valores posibles) incluyen:

- a) madurez (valores de la serie ISO/IEC 33000 u otros modelos de madurez);
- b) estado de implementación (pendiente, en proceso, parcialmente implementado, completamente implementado);
- c) prioridad (1, 2, 3, etc.);
- d) áreas organizacionales involucradas (seguridad, TIC, recursos humanos, alta dirección, etc.);
- e) eventos;
- f) bienes involucrados;
- g) construir y ejecutar, para diferenciar los controles utilizados en los diferentes pasos del ciclo de vida del servicio;
- h) otros marcos con los que trabaja la organización o desde los que puede estar en transición.

Anexo B (informativo)

Correspondencia de ISO/IEC 27002:2022 (este documento) con ISO/CEI 27002:2013

El propósito de este anexo es proporcionar compatibilidad con versiones anteriores de ISO/IEC 27002:2013 para las organizaciones que actualmente usan ese estándar y ahora desean hacer la transición a esta edición.

[Tabla B.1](#) proporciona la correspondencia de los controles especificados en [Cláusulas 5 a 8](#) con los de ISO/IEC 27002:2013.

**Tabla B.1 — Correspondencia entre los controles en este documento y los controles en
ISO/CEI 27002:2013**

YO ASI/ CEI 27002:2022 control identificador	ISO/CEI 27002:2013 identificador de control	nombre de control
5.1	05.1.1, 05.1.2	Políticas de seguridad de la información
5.2	06.1.1	Roles y responsabilidades de seguridad de la información
5.3	06.1.2	Segregación de deberes
5.4	07.2.1	responsabilidades de gestión
5.5	06.1.3	Contacto con autoridades
5.6	06.1.4	Contacto con grupos de interés especial
5.7	Nuevo	Inteligencia de amenazas
5.8	06.1.5, 14.1.1	Seguridad de la información en la gestión de proyectos.
5.9	08.1.1, 08.1.2	Inventario de información y otros activos asociados
5.10	08.1.3, 08.2.3	Uso aceptable de la información y otros activos asociados
5.11	08.1.4	Devolución de activos
5.12	08.2.1	Clasificación de la información
5.13	08.2.2	Etiquetado de información
5.14	13.2.1, 13.2.2, 13.2.3	Transferencia de información
5.15	09.1.1, 09.1.2	Control de acceso
5.16	09.2.1	Gestión de identidad
5.17	09.2.4, 09.3.1, 09.4.3	Información de autenticación
5.18	09.2.2, 09.2.5, 09.2.6	Derechos de acceso
5.19	15.1.1	Seguridad de la información en las relaciones con los proveedores
5.20	15.1.2	Abordar la seguridad de la información en los acuerdos con los proveedores
5.21	15.1.3	Gestión de la seguridad de la información en la cadena de suministro de las TIC
5.22	15.2.1, 15.2.2	Seguimiento, revisión y gestión de cambios de servicios de proveedores
5.23	Nuevo	Seguridad de la información para el uso de servicios en la nube
5.24	16.1.1	Planificación y preparación de la gestión de incidentes de seguridad de la información
5.25	16.1.4	Evaluación y decisión sobre eventos de seguridad de la información

Tabla B.1 (continuado)

YO ASI/ CEI 27002:2022 control identificador	ISO/CEI 27002:2013 identificador de control	nombre de control
5.26	16.1.5	Respuesta a incidentes de seguridad de la información
5.27	16.1.6	Aprender de los incidentes de seguridad de la información
5.28	16.1.7	Recolección de evidencia
5.29	17.1.1, 17.1.2, 17.1.3	Seguridad de la información durante la interrupción
5.30	Nuevo	Preparación de las TIC para la continuidad del negocio
5.31	18.1.1, 18.1.5	Requisitos legales, estatutarios, reglamentarios y contractuales
5.32	18.1.2	Derechos de propiedad intelectual
5.33	18.1.3	Protección de registros
5.34	18.1.4	Privacidad y protección de PII
5.35	18.2.1	Revisión independiente de la seguridad de la información.
5.36	18.2.2, 18.2.3	Cumplimiento de políticas, normas y estándares de seguridad de la información
5.37	12.1.1	Procedimientos operativos documentados
6.1	07.1.1	Poner en pantalla
6.2	07.1.2	Términos y condiciones de empleo
6.3	07.2.2	Concientización, educación y capacitación en seguridad de la información
6.4	07.2.3	Proceso Disciplinario
6.5	07.3.1	Responsabilidades después de la terminación o cambio de empleo
6.6	13.2.4	Acuerdos de confidencialidad o no divulgación
6.7	06.2.2	Trabajo remoto
6.8	16.1.2, 16.1.3	Informes de eventos de seguridad de la información
7.1	11.1.1	Perímetros físicos de seguridad
7.2	11.1.2, 11.1.6	Entrada física
7.3	11.1.3	Asegurar oficinas, salas e instalaciones
7.4	Nuevo	Monitoreo de seguridad física
7.5	11.1.4	Protección contra amenazas físicas y ambientales.
7.6	11.1.5	Trabajar en áreas seguras
7.7	11.2.9	Escritorio despejado y pantalla despejada
7.8	11.2.1	Emplazamiento y protección de equipos
7.9	11.2.6	Seguridad de los activos fuera de las instalaciones
7.10	08.3.1, 08.3.2, 08.3.3, 11.2.5	Medios de almacenamiento
7.11	11.2.2	Utilidades de apoyo
7.12	11.2.3	seguridad del cableado
7.13	11.2.4	Mantenimiento de equipo
7.14	11.2.7	Eliminación segura o reutilización de equipos
8.1	06.2.1, 11.2.8	Dispositivos de punto final de usuario
8.2	09.2.3	Derechos de acceso privilegiado
8.3	09.4.1	Restricción de acceso a la información
8.4	09.4.5	Acceso al código fuente
8.5	09.4.2	Autenticación segura
8.6	12.1.3	Gestión de capacidad
8.7	12.2.1	Protección contra malware

Tabla B.1 (continuado)

YO ASI/ CEI 27002:2022 control identificador	ISO/CEI 27002:2013 identificador de control	nombre de control
8.8	12.6.1, 18.2.3	Gestión de vulnerabilidades técnicas
8.9	Nuevo	Gestión de la configuración
8.10	Nuevo	Eliminación de información
8.11	Nuevo	Enmascaramiento de datos
8.12	Nuevo	Prevención de fuga de datos
8.13	12.3.1	Copia de seguridad de la información
8.14	17.2.1	Redundancia de las instalaciones de procesamiento de información
8.15	12.4.1, 12.4.2, 12.4.3	Inicio sesión
8.16	Nuevo	Actividades de seguimiento
8.17	12.4.4	Sincronización de reloj
8.18	09.4.4	Uso de programas de utilidad privilegiados
8.19	12.5.1, 12.6.2	Instalación de software en sistemas operativos
8.20	13.1.1	Seguridad en redes
8.21	13.1.2	Seguridad de los servicios de red.
8.22	13.1.3	Segregación de redes
8.23	Nuevo	Filtrado web
8.24	10.1.1, 10.1.2	Uso de criptografía
8.25	14.2.1	Ciclo de vida de desarrollo seguro
8.26	14.1.2, 14.1.3	Requisitos de seguridad de la aplicación
8.27	14.2.5	Principios de arquitectura e ingeniería de sistemas seguros
8.28	Nuevo	Codificación segura
8.29	14.2.8, 14.2.9	Pruebas de seguridad en desarrollo y aceptación.
8.30	14.2.7	Desarrollo subcontratado
8.31	12.1.4, 14.2.6	Separación de los entornos de desarrollo, prueba y producción
8.32	12.1.2, 14.2.2, 14.2.3, 14.2.4	Gestión del cambio
8.33	14.3.1	Información de prueba
8.34	12.7.1	Protección de los sistemas de información durante las pruebas de auditoría

[Tabla B.2](#) proporciona la correspondencia de los controles especificados en ISO/IEC 27002:2013 con los de este documento.

Tabla B.2 — Correspondencia entre los controles en ISO/IEC 27002:2013 y los controles en este documento

ISO/CEI 27002:2013 control identificador	YO ASI/ CEI 27002:2022 identificador de control	Nombre de control según ISO/IEC 27002:2013
5		Políticas de seguridad de la información
5.1		Dirección de gestión para la seguridad de la información.
5.1.1	5.1	Políticas de seguridad de la información
5.1.2	5.1	Revisión de las políticas de seguridad de la información
6		Organización de la seguridad de la información.

Tabla B.2(continuado)

ISO/CEI 27002:2013 control identificador	YO ASI/ CEI 27002:2022 identificador de control	Nombre de control según ISO/IEC 27002:2013
6.1		Organización interna
6.1.1	5.2	Roles y responsabilidades de seguridad de la información
6.1.2	5.3	Segregación de deberes
6.1.3	5.5	Contacto con autoridades
6.1.4	5.6	Contacto con grupos de interés especial
6.1.5	5.8	Seguridad de la información en la gestión de proyectos.
6.2		Dispositivos móviles y teletrabajo
6.2.1	8.1	política de dispositivos móviles
6.2.2	6.7	teletrabajo
7		seguridad de los recursos humanos
7.1		Antes del empleo
7.1.1	6.1	Poner en pantalla
7.1.2	6.2	Términos y condiciones de empleo
7.2		Durante el empleo
7.2.1	5.4	responsabilidades de gestión
7.2.2	6.3	Concientización, educación y capacitación en seguridad de la información
7.2.3	6.4	Proceso Disciplinario
7.3		Terminación y cambio de empleo
7.3.1	6.5	Terminación o cambio de responsabilidades laborales
8		Gestión de activos
8.1		Responsabilidad por los activos
8.1.1	5.9	Inventario de activos
8.1.2	5.9	Propiedad de los activos
8.1.3	5.10	Uso aceptable de los activos
8.1.4	5.11	Devolución de activos
8.2		Clasificación de la información
8.2.1	5.12	Clasificación de la información
8.2.2	5.13	Etiquetado de información
8.2.3	5.10	manejo de activos
8.3		manejo de medios
8.3.1	7.10	Gestión de medios extraíbles
8.3.2	7.10	Eliminación de medios
8.3.3	7.10	Transferencia de medios físicos
9		Control de acceso
9.1		Requisitos comerciales de control de acceso
9.1.1	5.15	Política de control de acceso
9.1.2	5.15	Acceso a redes y servicios de red
9.2		Gestión de acceso de usuarios
9.2.1	5.16	Alta y baja de usuario
9.2.2	5.18	Aprovisionamiento de acceso de usuarios
9.2.3	8.2	Gestión de derechos de acceso privilegiado
9.2.4	5.17	Gestión de la información secreta de autenticación de los usuarios

Tabla B.2(continuado)

ISO/CEI 27002:2013 control identificador	YO ASI/ CEI 27002:2022 identificador de control	Nombre de control según ISO/IEC 27002:2013
9.2.5	5.18	Revisión de los derechos de acceso de los usuarios
9.2.6	5.18	Eliminación o ajuste de los derechos de acceso
9.3		Responsabilidades del usuario
9.3.1	5.17	Uso de información de autenticación secreta
9.4		Control de acceso a sistemas y aplicaciones
9.4.1	8.3	Restricción de acceso a la información
9.4.2	8.5	Procedimientos seguros de inicio de sesión
9.4.3	5.17	Sistema de gestión de contraseñas
9.4.4	8.18	Uso de programas de utilidad privilegiados
9.4.5	8.4	Control de acceso al código fuente del programa
10		Criptografía
10.1		Controles criptográficos
10.1.1	8.24	Política sobre el uso de controles criptográficos
10.1.2	8.24	Gestión de claves
11		Seguridad física y ambiental
11.1		Áreas seguras
11.1.1	7.1	Perímetro de seguridad física
11.1.2	7.2	Controles de entrada física
11.1.3	7.3	Asegurar oficinas, salas e instalaciones
11.1.4	7.5	Protección contra amenazas externas y ambientales.
11.1.5	7.6	Trabajar en áreas seguras
11.1.6	7.2	Zonas de entrega y carga
11.2		Equipo
11.2.1	7.8	Emplazamiento y protección de equipos
11.2.2	7.11	Utilidades de apoyo
11.2.3	7.12	seguridad del cableado
11.2.4	7.13	Mantenimiento de equipo
11.2.5	7.10	Eliminación de activos
11.2.6	7.9	Seguridad de equipos y activos fuera de las instalaciones
11.2.7	7.14	Eliminación segura o reutilización de equipos
11.2.8	8.1	Equipo de usuario desatendido
11.2.9	7.7	Política de escritorio despejado y pantalla despejada
12		seguridad de las operaciones
12.1		Procedimientos operativos y responsabilidades
12.1.1	5.37	Procedimientos operativos documentados
12.1.2	8.32	Gestión del cambio
12.1.3	8.6	Gestión de capacidad
12.1.4	8.31	Separación de entornos de desarrollo, pruebas y operativos
12.2		Protección contra malware
12.2.1	8.7	Controles contra malware
12.3		Respaldo
12.3.1	8.13	Copia de seguridad de la información

Tabla B.2(continuado)

ISO/CEI 27002:2013 control identificador	YO ASI/ CEI 27002:2022 identificador de control	Nombre de control según ISO/IEC 27002:2013
12.4		Registro y monitoreo
12.4.1	8.15	El registro de eventos
12.4.2	8.15	Protección de la información de registro
12.4.3	8.15	Registros de administrador y operador
12.4.4	8.17	Sincronización de reloj
12.5		Control de software operativo
12.5.1	8.19	Instalación de software en sistemas operativos
12.6		Gestión de vulnerabilidades técnicas
12.6.1	8.8	Gestión de vulnerabilidades técnicas
12.6.2	8.19	Restricciones en la instalación de software
12.7		Consideraciones de auditoría de sistemas de información
12.7.1	8.34	Controles de auditoría de sistemas de información
13		Seguridad de las comunicaciones
13.1		Instalaciones de gestión de seguridad de red.
13.1.1	8.20	Controles de red
13.1.2	8.21	Seguridad de los servicios de red.
13.1.3	8.22	Segregación en redes
13.2		Transferencia de información
13.2.1	5.14	Políticas y procedimientos de transferencia de información
13.2.2	5.14	Acuerdos de transferencia de información
13.2.3	5.14	mensajería electrónica
13.2.4	6.6	Acuerdos de confidencialidad o no divulgación
14		Adquisición, desarrollo y mantenimiento del sistema
14.1		Requisitos de seguridad de los sistemas de información
14.1.1	5.8	Análisis y especificación de requisitos de seguridad de la información.
14.1.2	8.26	Protección de servicios de aplicaciones en redes públicas
14.1.3	8.26	Protección de transacciones de servicios de aplicaciones
14.2		Seguridad en los procesos de desarrollo y soporte
14.2.1	8.25	Política de desarrollo seguro
14.2.2	8.32	Procedimientos de control de cambios del sistema
14.2.3	8.32	Revisión técnica de aplicaciones tras cambios de plataforma operativa
14.2.4	8.32	Restricciones a los cambios en los paquetes de software
14.2.5	8.27	Principios de ingeniería de sistemas seguros
14.2.6	8.31	Entorno de desarrollo seguro
14.2.7	8.30	Desarrollo subcontratado
14.2.8	8.29	Pruebas de seguridad del sistema
14.2.9	8.29	Pruebas de aceptación del sistema
14.3		Datos de prueba
14.3.1	8.33	Protección de datos de prueba
15		Relaciones con proveedores
15.1		Seguridad de la información en las relaciones con los proveedores
15.1.1	5.19	Política de seguridad de la información en las relaciones con proveedores

Tabla B.2(continuado)

ISO/CEI 27002:2013 control identificador	YO ASI/ CEI 27002:2022 identificador de control	Nombre de control según ISO/IEC 27002:2013
15.1.2	5.20	Abordar la seguridad en los acuerdos con los proveedores
15.1.3	5.21	Cadena de suministro de tecnología de la información y la comunicación
15.2		Gestión de entrega de servicios de proveedores
15.2.1	5.22	Seguimiento y revisión de servicios de proveedores
15.2.2	5.22	Gestión de cambios en los servicios del proveedor
dieciséis		Gestión de incidentes de seguridad de la información
16.1		Gestión de incidentes y mejoras de seguridad de la información
16.1.1	5.24	Responsabilidades y procedimientos
16.1.2	6.8	Reportar eventos de seguridad de la información
16.1.3	6.8	Informar sobre debilidades en la seguridad de la información
16.1.4	5.25	Evaluación y decisión sobre eventos de seguridad de la información
16.1.5	5.26	Respuesta a incidentes de seguridad de la información
16.1.6	5.27	Aprender de los incidentes de seguridad de la información
16.1.7	5.28	Recolección de evidencia
17		Aspectos de seguridad de la información de la gestión de la continuidad del negocio
17.1		Continuidad de la seguridad de la información
17.1.1	5.29	Planificación de la continuidad de la seguridad de la información
17.1.2	5.29	Implementación de la continuidad de la seguridad de la información
17.1.3	5.29	Verificar, revisar y evaluar la continuidad de la seguridad de la información
17.2		despidos
17.2.1	8.14	Disponibilidad de instalaciones de procesamiento de información
18		Cumplimiento
18.1		Cumplimiento de requisitos legales y contractuales
18.1.1	5.31	Identificación de la legislación aplicable y requisitos contractuales
18.1.2	5.32	Derechos de propiedad intelectual
18.1.3	5.33	Protección de registros
18.1.4	5.34	Privacidad y protección de la información de identificación personal
18.1.5	5.31	Regulación de controles criptográficos
18.2		Revisiones de seguridad de la información
18.2.1	5.35	Revisión independiente de la seguridad de la información.
18.2.2	5.36	Cumplimiento de políticas y estándares de seguridad
18.2.3	5.36 , 8.8	Revisión de cumplimiento técnico

Bibliografía

- [1] ISO 9000, *Sistemas de gestión de la calidad — Fundamentos y vocabulario*
- [2] ISO 55001, *Gestión de activos — Sistemas de gestión — Requisitos*
- [3] ISO/IEC 11770 (todas las partes), *Seguridad de la información — Gestión de claves*
- [4] ISO/IEC 15408 (todas las partes), *Tecnologías de la información. Técnicas de seguridad. Criterios de evaluación de seguridad informática*
- [5] ISO 15489 (todas las partes), *Información y documentación — Gestión de registros*
- [6] ISO/CEI 17788, *Tecnología de la información — Computación en la nube — Visión general y vocabulario*
- [7] ISO/CEI 17789, *Tecnología de la información — Computación en la nube — Arquitectura de referencia*
- [8] ISO/IEC 19086 (todas las partes), *Informática en la nube: marco de acuerdo de nivel de servicio (SLA)*
- [9] ISO/IEC 19770 (todas las partes), *Tecnología de la información: gestión de activos de TI*
- [10] ISO/CEI 19941, *Tecnología de la información — Computación en la nube — Interoperabilidad y portabilidad*
- [11] ISO/CEI 20889, *Terminología de desidentificación de datos que mejora la privacidad y clasificación de técnicas*
- [12] ISO 21500, *Gestión de proyectos, programas y carteras — Contexto y conceptos*
- [13] ISO 21502, *Gestión de proyectos, programas y carteras — Orientación sobre la gestión de proyectos*
- [14] ISO 22301, *Seguridad y resiliencia — Sistemas de gestión de la continuidad del negocio — Requisitos*
- [15] ISO 22313, *Seguridad y resiliencia. Sistemas de gestión de la continuidad del negocio. Orientación sobre el uso de la norma ISO 22301.*
- [16] ISO/TS 22317, *Seguridad social — Sistemas de gestión de la continuidad del negocio — Directrices para el análisis de impacto empresarial (BIA)*
- [17] ISO 22396, *Seguridad y resiliencia — Resiliencia comunitaria — Directrices para el intercambio de información entre organizaciones*
- [18] ISO/CEI TS 23167, *Tecnología de la información — Computación en la nube — Tecnologías y técnicas comunes*
- [19] ISO/CEI 23751:—2), *Tecnología de la información — Computación en la nube y plataformas distribuidas — Marco de acuerdo de intercambio de datos (DSA)*
- [20] ISO/IEC 24760 (todas las partes), *Seguridad y privacidad de TI: un marco para la gestión de identidades*
- [21] ISO/CEI 27001:2013, *Tecnología de la información — Técnicas de seguridad — Sistemas de gestión de la seguridad de la información — Requisitos*
- [22] ISO/CEI 27005, *Tecnología de la información — Técnicas de seguridad — Gestión de riesgos de seguridad de la información*
- [23] ISO/CEI 27007, *Seguridad de la información, ciberseguridad y protección de la privacidad: Directrices para auditoría de sistemas de gestión de seguridad de la información*
- [24] ISO/CEI TS 27008, *Tecnología de la información. Técnicas de seguridad. Directrices para la evaluación de los controles de seguridad de la información.*

2) En preparación. Etapa en el momento de la publicación: ISO/IEC PRF 23751:2022.

- [25] ISO/CEI 27011, *Tecnología de la información. Técnicas de seguridad. Código de prácticas para los controles de seguridad de la información basado en ISO/IEC 27002 para organizaciones de telecomunicaciones.*
- [26] ISO/CEI TR 27016, *Tecnología de la información — Técnicas de seguridad — Gestión de la seguridad de la información — Economía organizacional*
- [27] ISO/CEI 27017, *Tecnología de la información — Técnicas de seguridad — Código de prácticas para los controles de seguridad de la información basado en ISO/IEC 27002 para servicios en la nube*
- [28] ISO/CEI 27018, *Tecnología de la información — Técnicas de seguridad — Código de prácticas para la protección de información de identificación personal (PII) en nubes públicas que actúan como procesadores de PII*
- [29] ISO/CEI 27019, *Tecnología de la información. Técnicas de seguridad. Controles de seguridad de la información para la industria de servicios públicos de energía.*
- [30] ISO/CEI 27031, *Tecnología de la información. Técnicas de seguridad. Directrices para la preparación de la tecnología de la información y las comunicaciones para la continuidad del negocio.*
- [31] ISO/IEC 27033 (todas las partes), *Tecnología de la información — Técnicas de seguridad — Seguridad de la red*
- [32] ISO/IEC 27034 (todas las partes), *Tecnología de la información: seguridad de las aplicaciones*
- [33] ISO/IEC 27035 (todas las partes), *Tecnología de la información — Técnicas de seguridad — Seguridad de la información administración de incidentes*
- [34] ISO/IEC 27036 (todas las partes), *Tecnología de la información. Técnicas de seguridad. Seguridad de la información para las relaciones con los proveedores.*
- [35] ISO/CEI 27037, *Tecnología de la información. Técnicas de seguridad. Directrices para la identificación, recopilación, adquisición y preservación de evidencia digital*
- [36] ISO/CEI 27040, *Tecnología de la información — Técnicas de seguridad — Seguridad del almacenamiento*
- [37] ISO/IEC 27050 (todas las partes), *Tecnología de la información — Descubrimiento electrónico*
- [38] ISO/CEI TS 27110, *Tecnología de la información, ciberseguridad y protección de la privacidad: directrices para el desarrollo del marco de ciberseguridad*
- [39] ISO/CEI 27701, *Técnicas de seguridad — Extensión a ISO/IEC 27001 e ISO/IEC 27002 para privacidad gestión de la información — Requisitos y directrices*
- [40] ISO 27799, *Informática de la salud — Gestión de la seguridad de la información en salud utilizando ISO/IEC 27002*
- [41] ISO/CEI 29100, *Tecnología de la información — Técnicas de seguridad — Marco de privacidad*
- [42] ISO/CEI 29115, *Tecnología de la información — Técnicas de seguridad — Marco de garantía de autenticación de entidades*
- [43] ISO/CEI 29134, *Tecnología de la información. Técnicas de seguridad. Directrices para la evaluación del impacto en la privacidad.*
- [44] ISO/CEI 29146, *Tecnología de la información. Técnicas de seguridad. Un marco para la gestión del acceso.*
- [45] ISO/CEI 29147, *Tecnología de la información — Técnicas de seguridad — Divulgación de vulnerabilidades*
- [46] ISO 30000, *Barcos y tecnología marina. Sistemas de gestión de reciclaje de barcos. Especificaciones. para sistemas de gestión de instalaciones de reciclaje de buques seguros y respetuosas con el medio ambiente*
- [47] ISO/CEI 30111, *Tecnología de la información — Técnicas de seguridad — Procesos de manejo de vulnerabilidades*
- [48] ISO 31000:2018, *Gestión de riesgos — Directrices*
- [49] CEI 31010, *Gestión de riesgos — Técnicas de evaluación de riesgos*

- [50] ISO/IEC 22123 (todas las partes), *Tecnología de la información: computación en la nube*
- [51] ISO/CEI 27555, *Seguridad de la información, ciberseguridad y protección de la privacidad: directrices sobre la eliminación de información de identificación personal*
- [52] Foro de Seguridad de la Información (ISF). Estándar ISF de buenas prácticas para la seguridad de la información 2020, agosto de 2018. Disponible en <https://www.securityforum.org/tool/standard-of-buenas-prácticas-para-la-seguridad-de-la-información-2020/>
- [53] ITIL® Foundation, ITIL 4 edición, AXELOS, febrero de 2019, ISBN: 9780113316076
- [54] Instituto Nacional de Estándares y Tecnología (NIST), SP 800-37, Marco de gestión de riesgos para sistemas y organizaciones de información: un enfoque del ciclo de vida del sistema para la seguridad y la privacidad, revisión 2. Diciembre de 2018 [consultado el 31 de julio de 2020] . Disponible en <https://doi.org/10.6028/NIST.SP.800-37r2>
- [55] Proyecto de seguridad de aplicaciones web abiertas (OWASP). OWASP Top Ten - 2017, Los diez riesgos de seguridad de aplicaciones web más críticos, 2017 [consultado el 31 de julio de 2020]. Disponible en https://owasp.org/www-project-top-ten/OWASP_Top_Ten_2017/
- [56] Proyecto de seguridad de aplicaciones web abiertas (OWASP). Guía para desarrolladores de OWASP, [en línea] [consultado el 22 de octubre de 2020]. Disponible en <https://github.com/OWASP/DevGuide>
- [57] Instituto Nacional de Estándares y Tecnología (NIST), SP 800-63B, Pautas de identidad digital; Autenticación y Gestión del Ciclo de Vida. Febrero de 2020 [consultado el 31 de julio de 2020]. Disponible en <https://doi.org/10.6028/NIST.SP.800-63b>
- [58] OASIS, Expresión estructurada de información sobre amenazas. Disponible en <https://www.oasis-open.org/standards#stix2.0>
- [59] OASIS, Intercambio Automatizado Confiable de Información de Indicadores. Disponible en <https://www.oasis-open.org/standards#taxii2.0>

